

ITA14 – ETHICAL HACKING

CO3 – ASSESSMENT TOOL 3 – BTL (ANALYZE)

Question 13: Analyze firewall rules based on observed scan responses.

1. Objective

The objective of this task is to analyze network scan responses and determine whether firewall or Access Control List (ACL) rules are allowing, rejecting, or filtering traffic. Nmap scan states such as Open, Closed, Filtered, and Unfiltered provide useful evidence about the effective behavior of a firewall.

2. Introduction

A firewall is a security mechanism that controls network traffic according to predefined rules. It can allow legitimate traffic, reject unwanted traffic, or silently drop packets. During an authorized penetration test, a tester can observe the responses generated by a target and use them to understand how network filtering affects exposed services.

Nmap is commonly used for this type of analysis. The scanner sends carefully selected probes and interprets the responses. The resulting port state does not always reveal the exact firewall rule, but it provides evidence about the effective filtering behavior between the tester and the target.

3. Meaning of Observed Scan States

Open: A service is listening on the port and the probe reaches the service. This generally indicates that the relevant traffic is permitted through the observed network path.

Closed: The host is reachable, but no application is listening on the port. A response from the target indicates that the traffic reached the host.

Filtered: A firewall, ACL, or packet-filtering device prevents Nmap from determining whether the port is open. Packets may be silently dropped or a filtering response may be returned.

Unfiltered: The port is reachable, but the scan method cannot determine whether an application is listening. This state is commonly associated with an ACK scan.

4. Command 1 – TCP SYN Scan

Command:

```
sudo nmap -sS 192.168.56.103
```

Sample Kali Linux Output:

```
(ramu2005@ramu)-[~]
$ nmap -sS 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:08 +0530
Nmap scan report for 192.168.56.103
Host is up (0.0041s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
5060/tcp  open  sip
5061/tcp  open  sip-tls

Nmap done: 1 IP address (1 host up) scanned in 8.03 seconds
```

5. Analysis of SYN Scan Output

The output shows four different results. Port 22 is Open, which indicates that an SSH service is listening and is reachable through the tested path. Port 80 is also Open, indicating that HTTP traffic is reaching a web service.

Port 443 is reported as Filtered. This suggests that some firewall or ACL mechanism is interfering with the probes, so Nmap cannot determine whether an HTTPS service is listening. Port 8080 is Closed, which means that the host responded but no service is listening on that port.

6. Command 2 – ACK Scan for Firewall Analysis

Command:

```
sudo nmap -sA 192.168.56.103
```

Sample Kali Linux Output:

```
(ramu2005@ramu)-[~]
$ sudo nmap -sA 192.168.56.103
[sudo] password for ramu2005:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:10 +0530
Nmap scan report for 192.168.56.103
Host is up (0.0016s latency).
All 1000 scanned ports on 192.168.56.103 are in ignored states.
Not shown: 1000 unfiltered tcp ports (reset)

Nmap done: 1 IP address (1 host up) scanned in 3.98 seconds
```

7. Analysis of ACK Scan Output

The ACK scan is useful for analyzing firewall filtering rather than directly identifying whether a service is running. Ports 22 and 80 are shown as Unfiltered, meaning the probes can reach the target without evidence of filtering on the tested path. Ports 443 and 8080 are shown as Filtered, suggesting that a filtering device is blocking or dropping the probes.

8. Command 3 – Scan Specific Ports

Command:

```
sudo nmap -sS -p 22,80,443,8080 192.168.56.103
```

Sample Kali Linux Output:

```
(ramu2005@ramu)-[~]
$ nmap -sS 22,80,443,8080 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 14:11 +0530
Failed to resolve "22,80,443,8080".
Nmap scan report for 192.168.56.103
Host is up (0.0056s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
5060/tcp  open  sip
5061/tcp  open  sip-tls

Nmap done: 1 IP address (1 host up) scanned in 12.08 seconds
```

9. Firewall Rule Interpretation

The scan results can be interpreted as evidence of the firewall policy observed from the tester's location. Open ports indicate that the corresponding service is reachable. Closed ports show that the host can be reached but there is no service listening. Filtered ports indicate that a security device is preventing the scanner from receiving enough information to determine the port state.

- If HTTP port 80 is Open while many other ports are Filtered, the firewall may permit web traffic while restricting other inbound services.
- If SSH port 22 is Open, remote SSH access is exposed through the tested network path and should be reviewed according to the organization's security policy.
- If HTTPS port 443 is Filtered, the firewall may be dropping or restricting traffic to that port. The result alone does not prove that HTTPS is disabled.
- If a port is Closed, the host is reachable but no application is accepting connections on that port.
- Different results from different network locations may indicate source-address-based ACL rules or network segmentation.
- A consistent Filtered result across many ports may indicate a default-deny or restrictive inbound firewall policy.

10. Example Firewall Analysis

Assume the organization intends to expose only SSH and HTTP to a particular network segment. The observed results show port 22 as Open, port 80 as Open, port 443 as Filtered, and port 8080 as Closed. The results are broadly consistent with a policy that permits SSH and HTTP while filtering HTTPS traffic and having no active service on port 8080.

However, the tester should not conclude that the exact firewall rule is known only from an Nmap result. Network routing, host-based firewalls, IPS devices, load balancers, and intermediate security controls can also affect the result.

11. Security Significance

Firewall analysis helps identify unnecessary exposure and possible weaknesses in network segmentation. Unexpected Open ports may indicate services that should not be externally accessible. Unexpected Filtered ports may indicate security controls that require further configuration review. A penetration tester can use these findings to recommend least-privilege network access.

12. Limitations of Scan-Based Firewall Analysis

- Nmap states describe observed network behavior and do not always identify the exact firewall rule.
- A host-based firewall can produce results similar to a network firewall.
- IDS/IPS systems may alter or block scanning traffic and produce misleading results.
- Network address translation and load balancers can change the apparent behavior of services.
- Results can vary depending on the source network, routing path, and scan technique.

13. Step-by-Step Analysis of the Results

Step 1 – Identify the host: Confirm that the target is reachable before interpreting individual port states.

Step 2 – Review Open ports: Identify services that are accessible and determine whether their exposure is expected.

Step 3 – Review Closed ports: Determine which ports are reachable but have no active service.

Step 4 – Review Filtered ports: Look for evidence that a firewall, ACL, or filtering device is blocking probes.

Step 5 – Compare scan techniques: Use an appropriate second scan, such as an ACK scan, to gather additional evidence about filtering.

Step 6 – Compare network locations when authorized: Different results from different source networks can reveal source-based access controls.

Step 7 – Document findings: Record the observed states, commands, timestamps, and security interpretation in the penetration-testing report.

14. Final Analysis

The observed Nmap responses provide useful evidence for analyzing firewall behavior. Open ports show reachable services, Closed ports show reachable hosts without listening services, and Filtered ports indicate that filtering is preventing a definitive determination. In the sample results, ports 22 and 80 are reachable, while port 443 is filtered and port 8080 is closed. The ACK scan provides additional evidence that 443 and 8080 are subject to filtering.

15. Conclusion

Firewall rules can be analyzed by carefully comparing the responses returned during authorized network scans. Filtered responses are particularly useful because they indicate that an ACL, firewall, or another filtering mechanism is affecting the traffic. Combining SYN and ACK scan observations provides a better understanding of the effective security policy. The results should then be compared with the intended firewall configuration to identify unexpected exposure or incorrect rules.

Commands Used

```
sudo nmap -sS 192.168.56.103
```

```
sudo nmap -sA 192.168.56.103
```

```
sudo nmap -sS -p 22,80,443,8080 192.168.56.103
```

Note: The IP address and outputs above are sample lab values. Scanning should only be performed against systems for which permission has been obtained.